

Trabajo Sumativo Unidad 2

Carrera:Ingeniería en Ciberseguridad
Asignatura:Seguridad en Redes

Profesor: Ewald Herman Hollstein

Fecha de envío: 24/11/2025

Nombre(s) de estudiante(s):

Javier Cerda Salas

Ignacio Silva

Contenido

1	Introducción	3
2	Desarrollo:.....	4
2.1	Sección A: Instalación y configuración de OpenVAS.....	4
2.2	Análisis.....	6
2.3	Riesgo General del Activo	6
2.4	Principales Vulnerabilidades Identificadas.....	7
2.4.1	Ejecución Remota de Código (RCE) en Java RMI.....	7
2.4.2	Múltiples Vulnerabilidades de RCE en EasyPHP Webserver	7
2.4.3	Servicios de Acceso Remoto Inseguros (rlogin/rsh).....	7
2.4.4	Credenciales por Defecto en el Servicio FTP.....	8
2.5	Análisis de Riesgo y Plan de Acción.....	8
3	Plan de Mitigación	9
3.1	Revisión de Políticas y Acciones Complementarias.....	9
3.1.1	Revisión de Políticas de Credenciales:	9
3.1.2	Revisión de Políticas de Software Obsoleto:.....	9
3.1.3	Hardening de Servicios:.....	9
3.1.4	Monitoreo:	10
3.2	Conclusiones.....	10
4	Bibliografía	10

1 Introducción

La seguridad en redes y comunicaciones constituye un pilar fundamental en la protección de los activos tecnológicos dentro de una organización. En un entorno cada vez más expuesto a amenazas, el análisis proactivo de vulnerabilidades permite identificar riesgos antes de que sean explotados, fortaleciendo así la continuidad operativa y la resiliencia de los sistemas.

Este trabajo tiene como objetivo aplicar los conocimientos adquiridos en la Unidad 2 mediante la instalación, configuración y uso de OpenVAS (Greenbone Vulnerability Management), una de las herramientas más utilizadas para la gestión de vulnerabilidades. A través de un escaneo controlado sobre un activo autorizado, se busca evaluar su estado de seguridad, clasificar las vulnerabilidades encontradas e interpretar su impacto potencial. El desarrollo de este informe permitirá demostrar la capacidad de análisis técnico y la elaboración de un informe ejecutivo orientado a tomadores de decisiones, particularmente a un Gerente de TI, integrando criterios de criticidad, exposición al riesgo y recomendaciones basadas en buenas prácticas de ciberseguridad



2 Desarrollo:

2.1 Sección A: Instalación y configuración de OpenVAS.

Se cambió la configuración de red a modo adaptador solo anfitrión, se procedió a instalar openVas(GVM) y luego chequear su estatus.

```
--$ sudo gvm-check-setup
gvm-check-setup 25.04.0
This script is provided and maintained by Debian and Kali.
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner)...
OK: OpenVAS Scanner is present in version 23.30.1.
OK: Notus Scanner is present in version 22.7.2.
OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
OK: gvm owns all files in /var/lib/openvas/gnupg
OK: redis-server is present.
OK: scanner (db.address setting) is configured properly using the redis-server socket: /var/run/redis-openvas/redis-server.sock
OK: the mqtt_server.uri is defined in /etc/openvas/openvas.conf
OK: gvm owns all files in /var/lib/openvas/plugins
OK: NVT collection in /var/lib/openvas/plugins contains 94893 NVTs.
OK: The notus directory /var/lib/notus/products contains 509 NVTs.
Checking that the obsolete redis database has been removed
OK: No old Redis DB
Starting ospd-openvas service
Waiting for ospd-openvas service
OK: ospd-openvas service is active.
OK: ospd-OpenVAS is present in version 22.9.0.
Step 2: Checking GVM Manager ...
OK: GVM Manager (gvmd) is present in version 26.5.0.
Step 3: Checking Certificates ...
OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pem.
OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
OK: SCAP data found in /var/lib/gvm/scap-data.
OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking PostgreSQL DB and user ...
OK: PostgreSQL version and default port are OK.
gvmd | _gvm | UTF8 | libc | es_CL.UTF-8 | es_CL.UTF-8 | | |
24645|pg-gvm|10|2200|f|22.6||
OK: At least one user exists.
Step 6: Checking Greenbone Security Assistant (GSA) ...
OK: Greenbone Security Assistant is present in version 24.7.0-git.
Step 7: Checking if GVM services are up and running ...
Starting gvmd service
Waiting for gvmd service
OK: gvmd service is active.
Starting gsad service
Waiting for gsad service
OK: gsad service is active.
Step 8: Checking few other requirements ...
OK: nmap is present.
OK: ssh-keygen found, LSC credential generation for GNU/Linux targets is likely to work.
OK: nsis found, LSC credential package generation for Microsoft Windows targets is likely to work.
OK: xsltproc found.
WARNING: Your password policy is empty.
SUGGEST: Edit the /etc/gvm/ppolicy.conf file to set a password policy.
Step 9: Checking greenbone-security-assistant ...
OK: greenbone-security-assistant is installed
```

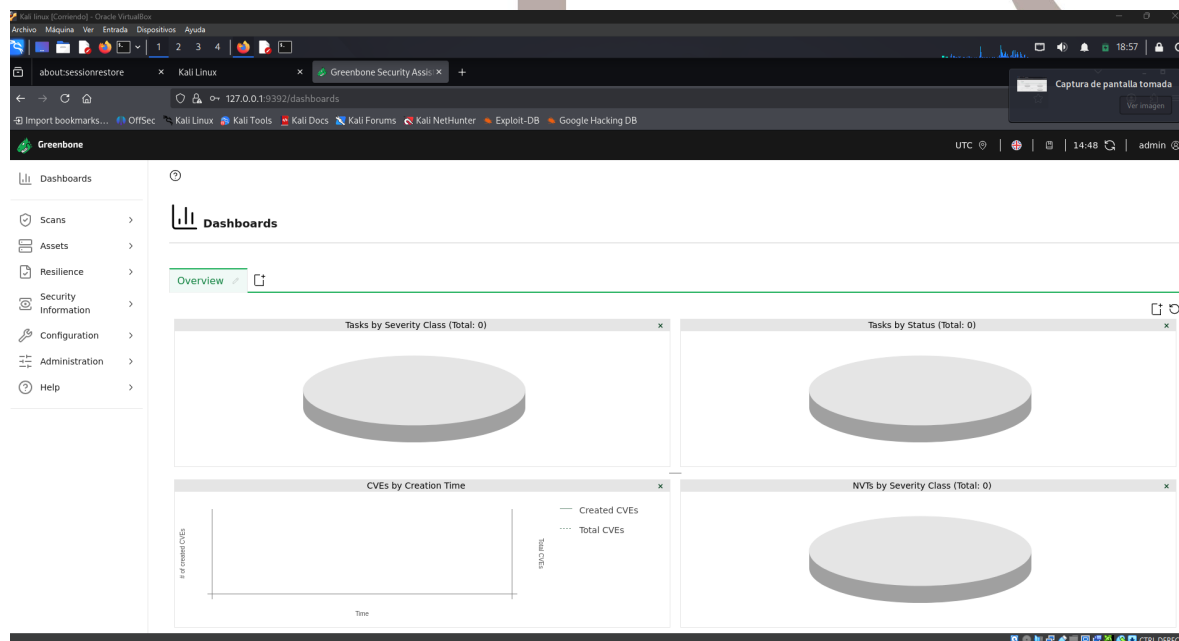
Por otro lado se procedió a instalar en otra máquina Metasploitable2 configurando su modo de red a **modo adaptador solo anfitrión** con el fin de aislar la red mientras se realizaba el escaneo.

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:9d:a7:ce
          inet addr:192.168.56.102  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe9d:a7ce/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:15 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4438 (4.3 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020  Memory:f0200000-f0220000

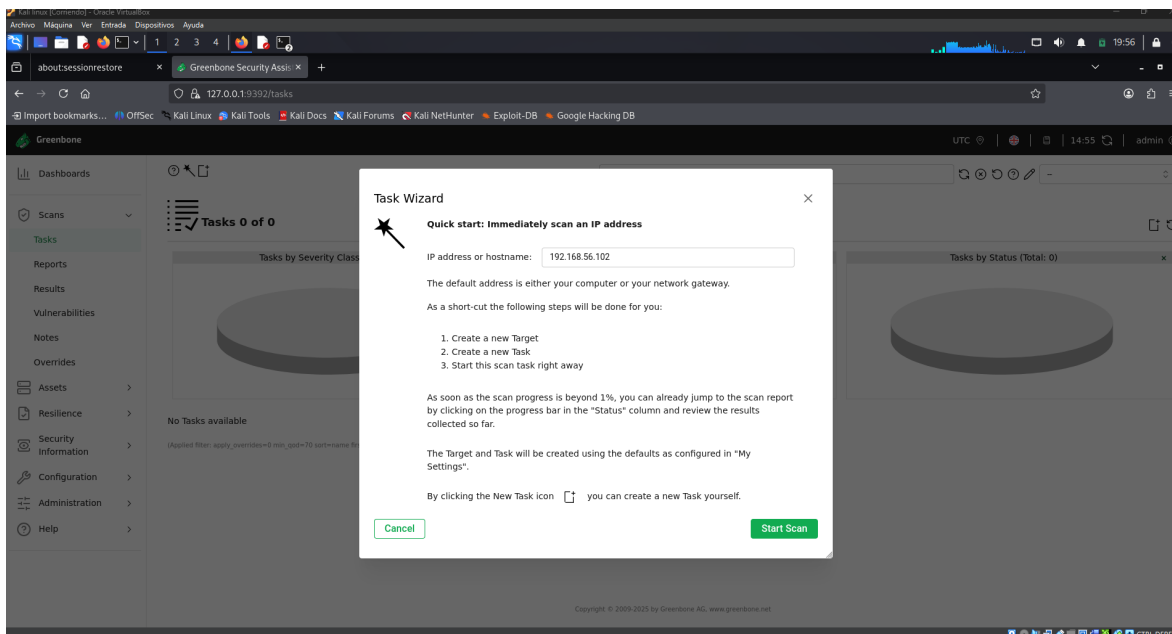
lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$
```

Una vez instalado GVM se inició en kali, como se observa en la siguiente imagen:



Tras ello se insertó el target y se configuro el tipo de escaneo full, la ip ingresada como target corresponde a la ip de Metasploitable 2, como se observa en la siguiente imagen:



2.2 Análisis

Se realizó un escaneo a la maquina metasploitable 2 , en dos ocasiones quedando el análisis en un 98%.

La ip de la máquina de metasploitable2 fue 192.168.56.102. Donde el resumen de las vulnerabilidades encontradas fue el siguiente, que se desglosa en la tabla:

Criticidad	Número de Vulnerabilidades
Críticas	0 (No se reportan explícitamente, pero las Altas tienen CVSS hasta 7.5)
Altas	8
Medias	40
Bajas	5
Total	53

2.3 Riesgo General del Activo

Dado el número y la naturaleza de las vulnerabilidades encontradas, incluyendo 8 fallos de criticidad Alta que permiten la ejecución de código remoto o la obtención de credenciales sin cifrar, el riesgo general del activo se clasifica como Alto. La explotación de estos fallos podría resultar en el compromiso total del sistema.

2.4 Principales Vulnerabilidades Identificadas

Se detallan las 4 vulnerabilidades de criticidad Alta identificadas en el escaneo que se consideraron de mayor importancia.

2.4.1 Ejecución Remota de Código (RCE) en Java RMI

Esta es la más grave, ya que permite a un atacante tomar control total del activo sin necesidad de autenticación.

Campo	Detalle
Nombre de la vulnerabilidad	Java RMI Server Insecure Default Configuration RCE Vulnerability.
CVE asociado	CVE-2011-3556.
Impacto en el activo	Ejecución de Código Arbitrario Remoto (RCE) con privilegios elevados. Un atacante no autenticado puede comprometer por completo el sistema.
Recomendación general de mitigación	Aplicar el parche de seguridad del proveedor. Como medida paliativa inmediata, deshabilitar la carga de clases en el servidor Java RMI.

2.4.2 Múltiples Vulnerabilidades de RCE en EasyPHP Webserver

Un fallo de software obsoleto con múltiples vectores de ataque, incluyendo la inyección de *shell*.

Campo	Detalle
Nombre de la vulnerabilidad	EasyPHP Webserver <= 12.1 Multiple Vulnerabilities.
CVE asociado	N/A (Múltiples fallos en versiones antiguas).
Impacto en el activo	Acceso para inyectar una shell de PHP o ejecutar código remoto, lo que resulta en un compromiso severo, pérdida de datos o desfiguración.
recomendación general de mitigación	Actualizar a una versión reciente y con soporte o migrar a una plataforma de servidor web segura. Si no es necesario, desinstalar el producto.

2.4.3 Servicios de Acceso Remoto Inseguros (rlogin/rsh)

El uso de estos servicios antiguos expone las credenciales de los usuarios más allá de la simple RCE.

Campo	Detalle
Nombre de la vulnerabilidad	El servicio rlogin se está ejecutando.

CVE asociado	CVE-1999-0651.
Impacto en el activo	Robo de credenciales en texto plano mediante sniffing de red. Además, permite potencialmente el inicio de sesión remoto sin contraseña y la ejecución de comandos remotos con privilegios del usuario.
Recomendación general de mitigación	Deshabilitar inmediatamente los servicios rlogin (Puertos 513/tcp y utilizar SSH con cifrado fuerte.

2.4.4 Credenciales por Defecto en el Servicio FTP

Esta vulnerabilidad es crítica por su facilidad de explotación (el "camino más fácil" para un atacante).

Campo	Detalle
Nombre de la vulnerabilidad	FTP Brute Force Logins With Default Credentials Reporting (Uso de credenciales por defecto/débiles).
CVE asociado	Múltiples, como CVE-1999-0501.
Impacto en el activo	Acceso no autorizado al sistema de archivos mediante el protocolo FTP, permitiendo a un atacante leer, modificar o eliminar datos sensibles o inyectar malware.
Recomendación general de mitigación	1. Cambiar todas las contraseñas por defecto (ej. msfadmin:msfadmin) por contraseñas robustas y únicas. 2. Auditar y deshabilitar todas las cuentas que usan credenciales por defecto/débiles.

2.5 Análisis de Riesgo y Plan de Acción

El nivel de exposición del activo **192.168.56.102** es clasificado como **ALTO** debido a los siguientes factores:

1. **Potencial de Compromiso Total (RCE):** La presencia de vulnerabilidades de Ejecución Remota de Código (RCE) en los servicios **Java RMI (CVE-2011-3556)** y **EasyPHP Webserver** permite a un atacante no autenticado obtener el control completo y persistente sobre el sistema.
2. **Exposición de Credenciales en Texto Plano:** La activación de servicios obsoletos como **rlogin** y **rsh** expone las credenciales de usuario a cualquier atacante que pueda interceptar el tráfico de red (Man-in-the-Middle o *sniffing*).

3. **Riesgo de Acceso Inmediato:** El uso de **Credenciales por Defecto en FTP** ofrece el camino de menor resistencia para un atacante, proporcionando acceso inmediato al sistema de archivos del servidor.
4. **Debilidad de Cifrado (MITM):**

La vulnerabilidad **OpenSSL CCS (CVE-2014-0224)** en el servicio PostgreSQL (5432/tcp) debilita la confianza de las comunicaciones cifradas, permitiendo potenciales ataques MITM para espiar o manipular la información de la base de datos.

En resumen, el activo es un objetivo fácil de explotar y presenta múltiples vías para que un atacante logre la escalada de privilegios y el compromiso total.

3 Plan de Mitigación

La estrategia de mitigación debe enfocarse en la eliminación de las vulnerabilidades más críticas que permiten RCE y la obtención de credenciales.

Se recomienda abordar las mitigaciones siguiendo esta estricta priorización (del 1 al 4, siendo 1 la acción más urgente):

3.1 Revisión de Políticas y Acciones Complementarias

Además de las acciones de parcheo específicas, se deben implementar las siguientes políticas de seguridad:

3.1.1 Revisión de Políticas de Credenciales:

- Implementar una política de cambio de contraseñas obligatoria para todos los servicios que actualmente utilizan credenciales por defecto o débiles.
- Asegurar que las credenciales no sean reusadas en diferentes servicios.

3.1.2 Revisión de Políticas de Software Obsoleto:

- Establecer un proceso de inventario y seguimiento para todos los componentes instalados (EasyPHP, Java RMI, etc.).
- Eliminar todo software que haya alcanzado su fin de vida útil y que, por lo tanto, no reciba parches de seguridad (ej. EasyPHP Webserver <= 12.1).

3.1.3 Hardening de Servicios:

- Deshabilitar servicios innecesarios: Si FTP (21/tcp), rlogin (513/tcp) o rsh (514/tcp) no son estrictamente necesarios, deben ser deshabilitados a nivel de *firewall* o de sistema operativo.

- Configuración Segura de SSH: Verificar que la configuración de SSH (el reemplazo de rlogin/rsh) solo permita algoritmos de cifrado y MAC fuertes (como se detalla en las vulnerabilidades de criticidad Media del informe completo).

3.1.4 Monitoreo:

- Implementar monitoreo de logs para cualquier intento de acceso a los servicios vulnerables antes de su mitigación completa.
- Programar re-escaneos periódicos (semanales o mensuales) con OpenVAS o herramientas similares para confirmar la mitigación exitosa de las 53 vulnerabilidades.

3.2 Conclusiones

El análisis junto a las vulnerabilidades encontradas, vislumbran que la maquina analizada es un objetivo con múltiples brechas lo que genera un blanco fácil para una escalada de privilegios mediante múltiples opciones.

Se recomienda abordar la mitigación de las vulnerabilidades en el orden propuesto mediante las tablas realizadas mostradas con anterioridad.

4 Bibliografía

Harris, S. (2022). CISSP All-in-One Exam Guide (9th ed.). McGraw-Hill Education.

National Institute of Standards and Technology. (2022). *NIST Special Publication 800-40 Revision 4: Guide to Enterprise Patch Management Planning*. U.S. Department of Commerce.

Scarfone, K., & Mell, P. (2016). *Guide to Intrusion Detection and Prevention Systems (IDPS)* (NIST SP 800-94). National Institute of Standards and Technology.